

TRAINING @ FORREST.ONE

Session 11 of 12

Network Fundamentals + CompTIA Security+ SY0-701

Security Operations: Monitoring, Incident Response & Forensics

When the alarm rings: monitoring that works, a response lifecycle that contains the damage, and forensics that stand up in court.

LESSONS 12-13

INCIDENT RESPONSE

FORENSICS



WELCOME · WHERE WE ARE

When the alarm rings

- **Sessions 1–10** prevented, detected, hardened
- **Today** the controls that watch, the response that contains, the forensics that prove
- **Six chapters** monitoring devices, endpoint and data controls, identity, response, hunting, logs
- **The exam** Domain 4 is the largest: phases, controls and evidence are direct objectives



SESSION OBJECTIVES

By the end of this session you will be able to

- **Design monitoring** firewall, IDS/IPS, and signature against anomaly detection
- **Place the controls** DNS filtering, DLP, NAC, EDR and XDR at the right layer
- **Protect identity** provisioning, SSO, federation, MFA and privileged access
- **Automate safely** playbooks, orchestration and human oversight
- **Run incident response** four phases, classification, severity, roles and testing
- **Hunt and investigate** threat hunting, root cause analysis, forensics and logs
- **Read indicators** malware, network, application and behavioural



CHAPTER 1 · MONITORING AND NETWORK SECURITY DEVICES

Firewall types

- **Packet filtering** network layer: matches source, destination, protocol and port
- **Its limit** fast, but no connection state and no inspection inside the payload
- **Stateful inspection** keeps a state table and judges each packet by its conversation
- **Next-generation firewall (NGFW)** application awareness, deep packet inspection, intrusion prevention
- **The progression** each type adds context the one before it could not see
- **The exam line** an NGFW sees the application, not merely the port



Firewall rules and segmentation

- **Rule creation** specific rules, so only authorised traffic passes
- **Change control** documentation, review and approval before any rule changes
- **Regular review** remove obsolete and redundant rules nobody can justify
- **Segmentation** corporate against guest, demilitarized zone (DMZ) against internal
- **Why it matters** each area carries its own policy, and the attack surface shrinks
- **The warning** a forgotten allow rule is a permanent hole in the policy



Web application firewalls

- **Web application firewall (WAF)** layer 7 protection for web applications
- **What it reads** HTTP and HTTPS requests, not merely packets
- **What it blocks** Structured Query Language (SQL) injection, cross-site scripting and similar web attacks
- **Deployment** as an appliance, as software, or as a cloud service
- **Why web applications** internet-facing applications are the ones attackers reach first
- **The principle** the request is where the attack arrives, so that is where you answer it



Intrusion detection and prevention

- **Intrusion detection system (IDS)** passive: detects and alerts, but takes no direct action
- **Intrusion prevention system (IPS)** inline: drops packets, blocks addresses, resets connections
- **Network-based sensor** sits at a gateway and sees traffic entering and leaving
- **Host-based agent** sits on a server or workstation and catches activity from inside
- **The distinction** detection informs, prevention intervenes



CHAPTER 1 · MONITORING AND NETWORK SECURITY DEVICES

Two ways to detect

Method	How it works	Strength	Weakness
Signature-based	Matches traffic against a database of known attack patterns	Very effective on known threats	Blind to a novel technique
Anomaly-based	Builds a baseline of normal activity, alerts on deviation	Can catch unknown threats	More false positives

Tuning balances the two

Update the signatures, adjust the thresholds, allowlist known good activity, and review alerts regularly. An untuned sensor becomes wallpaper.



Analyst's lens: the host's own log

- **The source** on a Kali Linux box, the xrdp system log records every RDP connection
- **What it holds** successful and failed authentication, session start and stop, source address and port
- **The pattern to hunt** a run of failures then a success from one address suggests brute force that worked

Analyst's lens: reading a Remote Desktop Protocol (RDP) session log

Monitor the host, not only the network. Host logs record the attempts that network sensors never see.



DISCUSSION

The IDS has been alerting all week and the team has stopped reading it. What has failed, and what do you fix first?

Probe: this is an alerting failure, not a detection failure. Baselines, thresholds and tuning restore the signal; an untuned sensor is just noise.

Detection without tuning becomes wallpaper.



CHAPTER 2 · ENDPOINT AND DATA CONTROLS

Domain Name System filtering

- **What it does** blocks access to domains that are malicious or against policy
- **Where it acts** intercepts the name resolution query, before any connection is established
- **The decision** checks the requested domain against a blocklist or an allowlist
- **What the user sees** the request is denied, with a warning page or an error message
- **Why it works** phishing and malware distribution sites never get a connection
- **The principle** the cheapest place to stop a connection is before it starts



CHAPTER 2 · ENDPOINT AND DATA CONTROLS

Data loss prevention

- **Data loss prevention (DLP)** monitors, detects and controls the movement of sensitive data
- **Network DLP** data in motion across the network
- **Endpoint DLP** data at rest and data in use on the device itself
- **Rules match** content, context and user action
- **The actions** alert an administrator, block the transfer, or encrypt the data
- **The classic case** an employee emails a client file to a personal address, and the system stops it



CHAPTER 2 · ENDPOINT AND DATA CONTROLS

Network access control

- **Network access control (NAC)** decides who gets onto the network in the first place
- **The posture check** antivirus status, operating system updates and user credentials
- **A compliant device** allowed on, with the access the policy intends
- **A non-compliant device** denied, or placed in a restricted segment until it complies
- **Where it is used** offices, schools and healthcare, where trust must be earned
- **The three together** filtering guards the domains, DLP guards the data, NAC guards the devices



CHAPTER 2 · ENDPOINT AND DATA CONTROLS

Endpoint detection and response

- **Traditional antivirus** scans files against a database of known malware signatures
- **Its blind spot** zero-day attacks and advanced persistent threats (APTs)
- **Endpoint detection and response (EDR)** watches behaviour, not just signatures
- **The telemetry** process trees, file modifications and network connections
- **What it flags** a process that opens sensitive files or makes an unusual connection
- **The output** process trees and telemetry, rather than a simple verdict



CHAPTER 2 · ENDPOINT AND DATA CONTROLS

Alert investigation workflow

Step	What happens
1 Alert triage	Prioritise by severity and potential impact
2 Threat analysis	Review the telemetry: process activity, file changes, connections
3 Contextualisation	Establish origin, affected systems, indicators of compromise
4 Response planning	Decide to contain, eradicate, or add controls
5 Remediation and recovery	Restore the system, patch it, then review the lessons

Extended detection and response (XDR)

Correlates endpoint, network and cloud data in one view, and can isolate an endpoint, quarantine a file, block an address or revoke credentials.



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Provisioning and the user lifecycle

- **Identity and access management (IAM)** controls who has access to what
- **Onboarding** create accounts with the roles and permissions the job requires
- **Role change** modify the account, so old rights are removed with the old job
- **Offboarding** deactivate or remove the account when someone leaves
- **The common failure** offboarding done late is one of the most common audit findings
- **The principle** access should follow the job, and leave when the person does



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Single sign-on, directories and federation

- **Single sign-on (SSO)** one credential opens many systems
- **Its cost** a single point of failure, so pair it with multifactor authentication
- **Directory services** Active Directory, Lightweight Directory Access Protocol (LDAP), cloud directories
- **Federation** trust between an identity provider and a service provider, proven by a token
- **Identity governance** access reviews, policy enforcement, and audit reporting
- **The tension** one password to steal is also one password to protect



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Multifactor authentication

Factor	Examples	Typical weakness
Something you know	Password, pin	Phishing and reuse
Something you have	Phone, smart card, hardware token	Can be stolen with the device
Something you are	Fingerprint, face, iris	Cannot be changed if compromised

Two passwords are still a single factor

Combining factors from different categories is what defeats a stolen password. Implementations include time-based one-time passwords (TOTP), hardware tokens and biometrics.



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Privileged access management

- **Privileged access management (PAM)** controls the accounts that can do real damage
- **Just-in-time access** elevated rights granted when needed, revoked automatically
- **Session recording** keystrokes, commands and applications captured for audit and forensics
- **Password vaulting** privileged credentials stored encrypted and rotated automatically
- **The outcome** nobody memorises the password, and every use is logged
- **The standard** every use of a privileged credential is attributable to a person



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Automation use cases

- **What automation buys** security tasks with little human intervention, less delay and less error
- **Automated patching** scan, test in a controlled environment, deploy
- **Why patching** it shortens the window of exposure to a known vulnerability
- **Account provisioning** access granted and revoked promptly where staff change role often
- **Incident response playbooks** isolate, notify the right people, collect forensic data
- **The difference** responding in seconds, rather than responding tomorrow



CHAPTER 3 · IDENTITY, ACCESS AND AUTOMATION

Orchestration, scripting and guardrails

- **Orchestration** automated tasks coordinated into one workflow, in the correct sequence
- **A workflow** detect a threat, trigger a patch, update threat intelligence, untouched by hand
- **Scripting** customisation, efficiency and consistency, because a script repeats exactly
- **Guardrails** test changes, restrict who may edit scripts, log every automated action
- **Human oversight** for complex judgement, exceptions and decisions with ethical weight
- **The balance** automate the routine, keep a person on the judgement



BREAK
10 MINUTES

Back soon: incident response. Preparation, detection, containment, eradication, recovery, and lessons learned.



CHAPTER 4 · INCIDENT RESPONSE

The four phases

1**Preparation**

policy, tools, a written plan, trained people

2**Detection and analysis**

identify it, scope it, grade it

3**Containment, eradication, recovery**

isolate, remove the cause, restore

4**Lessons learned**

document it, update the plan

The order is examined directly

Preparation comes first, always. Get the sequence wrong in a scenario question and you lose the mark.



CHAPTER 4 · INCIDENT RESPONSE

Containment, eradication and recovery

- **Containment strategy** short-term isolation first, then long-term control
- **The trade-off** containment preserves evidence, but can alert the adversary
- **Eradication** remove the malware, revoke the credentials, close the hole
- **Recovery** restore from validated backups, then verify integrity
- **Post-incident monitoring** intensified, watching for re-infection
- **The exam line** containment stops the bleeding, eradication stops the cause



CHAPTER 4 · INCIDENT RESPONSE

Classification, severity and roles

- **Classification** unauthorised access, malware, denial of service, data breach
- **Severity** low, medium, high, critical, which drives the urgency of response
- **Incident handlers** detect, analyse, contain, eradicate and recover
- **Management** resources, oversight and external stakeholders
- **Legal** regulatory compliance and the protection of evidence
- **Communications** internal and external messaging, and reputation
- **The principle** severity drives urgency, and named roles prevent hesitation



CHAPTER 4 · INCIDENT RESPONSE

Tabletop, functional and full-scale

- **Tabletop** discussion-based: the team walks a scenario and talks through the decisions
- **Why tabletop** it exposes gaps in the plan and the communication flow at very low cost
- **Functional** hands-on with real tools, testing specific capabilities under pressure
- **Full-scale** multiple teams, all roles performed, end to end
- **The graduation** each kind tests more of the plan than the one before it
- **The warning** a plan that has never been exercised is a document, not a capability



CHAPTER 4 · INCIDENT RESPONSE

Training and after-action review

- **Responder training** ongoing: detection, analysis, response strategy and the tools
- **General staff awareness** recognise phishing, report suspicious activity, follow policy
- **After-action review** what went well, what was difficult, what must change
- **The loop** findings feed straight back into the plan and future exercises
- **The example** communication gaps between departments become clearer protocols
- **The point** the review is where the improvement actually happens



Threat hunting methods

- **The assumption** an attacker is already inside, and the alerts missed them
- **Hypothesis-driven** form an idea, then test it with targeted searches
- **An example** rising failed logins suggest brute force, so search one address against many accounts
- **Indicator sweeping** search the estate for known indicators of compromise
- **The indicators** addresses, file hashes and domain names
- **The return** findings sharpen the detection rules for the next attempt



CHAPTER 5 · THREAT HUNTING AND FORENSIC EVIDENCE

Root cause analysis

- **The question** why, not just what: past the symptoms to the underlying weakness
- **Identify** state the problem clearly
- **Gather** collect data from logs, alerts and other sources
- **Analyse** look for patterns and anomalies
- **Find the causes** a configuration, a behaviour, or a vulnerability
- **Fix and verify** develop and implement solutions, then monitor their effect
- **The warning** without that last step, the same incident comes back



Collecting and preserving evidence

- **Digital forensics** collects, preserves and analyses electronic evidence
- **Collection** computers, mobile devices and network systems
- **Write blockers** prevent any change to the original storage device
- **Forensic imaging** an exact bit-by-bit copy, including deleted and hidden data
- **Hash verification** compare the hash of the original against the hash of the image
- **File carving** recovering files from raw disk without the filesystem
- **Capture order** volatile evidence first: registers, then memory, then disk
- **The rule** analyse the copy, never the original



CHAPTER 5 · THREAT HUNTING AND FORENSIC EVIDENCE

Chain of custody and legal requirements

- **Chain of custody** every person who handled the evidence, when it moved, and why
- **Why it matters** an unbroken chain proves control, and a break makes evidence inadmissible
- **Authorisation** a search warrant or the consent of the data owner, before collection
- **Privacy law** the General Data Protection Regulation (GDPR) still applies
- **US law** the Electronic Communications Privacy Act (ECPA) shapes what you may keep
- **Presentation** evidence must be organised, documented and reported to be credible



QUIZ

Activity: handle the evidence

- A compromised server is found: what do you capture first, and why?
- An analyst needs the RAM: what happens before any analysis?
- Two investigators handle the disk: what must they record?
- Debrief: what breaks the case in court?

Volatile first (RAM, connections); image and hash before analysing; document every handover: break the chain and it is inadmissible.



CHAPTER 6 · LOGS, INVESTIGATION AND CONSOLIDATION

Key log sources

- **Security logs** successful and failed logins, privilege changes
- **System logs** boot events, hardware changes, system errors
- **Application logs** errors, user interactions, transactions
- **Network device logs** routers and switches: traffic, status, configuration change
- **Firewall logs** allowed and denied traffic, which shows the attack arriving
- **The principle** different sources, one timeline



CHAPTER 6 · LOGS, INVESTIGATION AND CONSOLIDATION

Collection, centralisation and retention

- **Collection** gather from every source, in real time where possible, usually by agents
- **Centralisation** aggregate into one repository, commonly a SIEM
- **Correlation** events from different systems become a single story
- **Retention policy** how long logs are kept, when they are archived, when deleted
- **What sets retention** regulation, and the needs of your own investigations
- **The consequence** you cannot investigate what you never kept



CHAPTER 6 · LOGS, INVESTIGATION AND CONSOLIDATION

Beyond logs: captures, memory and metadata

- **Network capture** the traffic itself, for anomaly and intrusion analysis
- **Memory forensics** running processes, open connections, malware remnants
- **Why memory** often the only trace a sophisticated attack leaves behind
- **Metadata analysis** creation dates, authorship, modification history
- **The principle** each one covers what a plain log cannot



INDICATORS · MALWARE AND NETWORK

Malware indicators

Indicator	What it looks like
Virus / worm	Self-replicating code; spreading files, scanning activity
Trojan	Benign-looking software doing malicious work
Ransomware	Encrypted files, ransom notes, mass renames
Spyware / keylogger	Silent exfiltration of credentials and data
Rootkit	Hidden presence, with privileges maintained stealthily
Botnet	Command-and-control traffic, coordinated activity



Reading the indicators

Layer	Indicator	What it looks like
Network	Port scanning	Rapid probes across ports and hosts: reconnaissance
Network	Data exfiltration	Sudden outbound spikes as data leaves the network
Network	Command and control	Small, regular connections to a suspicious host
Application	Web and email	Injection probes, scanning paths, spoofed senders
Behaviour	Privilege escalation	Accounts gaining rights they should not have
Behaviour	Impossible travel	Logins from locations too far apart in time to be real

The lesson: traffic and behaviour anomalies are often the first signal, and different monitoring layers catch different ones.



QUIZ

Activity: read the indicators

- A server sends 1MB every 10 minutes to an unknown IP: what is it?
- A user logs in from London and Sydney in 10 minutes: what is it?
- Files are renamed to .locked with a note file: what is it?
- Debrief: which indicator would you have caught first?

C2 beacon, impossible travel, ransomware: monitoring layers catch different ones.



EXAM ALIGNMENT

What this maps to in the exam

Objective	What the exam tests
11.1 Monitoring & alerting	Data sources; baselines; thresholds; alert fatigue
11.2 Incident response	Lifecycle phases; containment; eradication; recovery
11.3 Forensics	Chain of custody; order of volatility; imaging; techniques
11.4 Indicators	Malware, network, application and behavioural IoCs

The chapter map behind those objectives

Monitoring devices, endpoint and data controls, identity and automation, incident response, hunting and forensics, then logs.



QUIZ

Check your understanding

- Open Quiz_Session_11.html in your browser.
- 20 questions, immediate feedback, exam-objective tag on every question.
- Read each explanation, because the distractors teach as much as the answer.
- Score 70%+ before moving on.

Every question maps to a CompTIA exam objective, for example 11.2 Incident Response.



KEY TAKEAWAYS

- **Monitoring** use the right sources and tune the alerts, or good alarms get ignored.
- **Match control to layer** firewall and NGFW, NAC, DLP, EDR.
- **Identity** provision, deprovision, and protect privilege.
- **Respond** through the four phases, and test the plan before you need it.
- **Preserve** volatile evidence first, and keep the chain of custody unbroken.
- **Logs** know your sources, and know how long you retain them.



REVISION CHECKLIST

Before next session

- **Retake the quiz** until you score 70%+ without guessing
- **Write a playbook** which steps you would automate, and where a human must decide
- **Walk the four phases** who leads, what tools, when to escalate
- **Practise volatility** list your own systems in capture order, memory before disk
- **Read ahead** Session 12: governance, risk, compliance and data protection



NEXT SESSION

Session 12: Governance, Risk, Compliance & Exam Consolidation

- Security governance: policies, standards, procedures
- Risk management processes and vendor risk
- Compliance, privacy and data protection

